

Quality Gates für **KI-Code**.

Was ein Gate heute bei jedem Pull Request prüfen kann,
wo es aufhört und was wir als Nächstes bauen.

Ein Build-Log des unslop-Teams. Die Forschungszahlen stammen
aus Studien Dritter, mit Quelle auf jeder Seite.

Checks

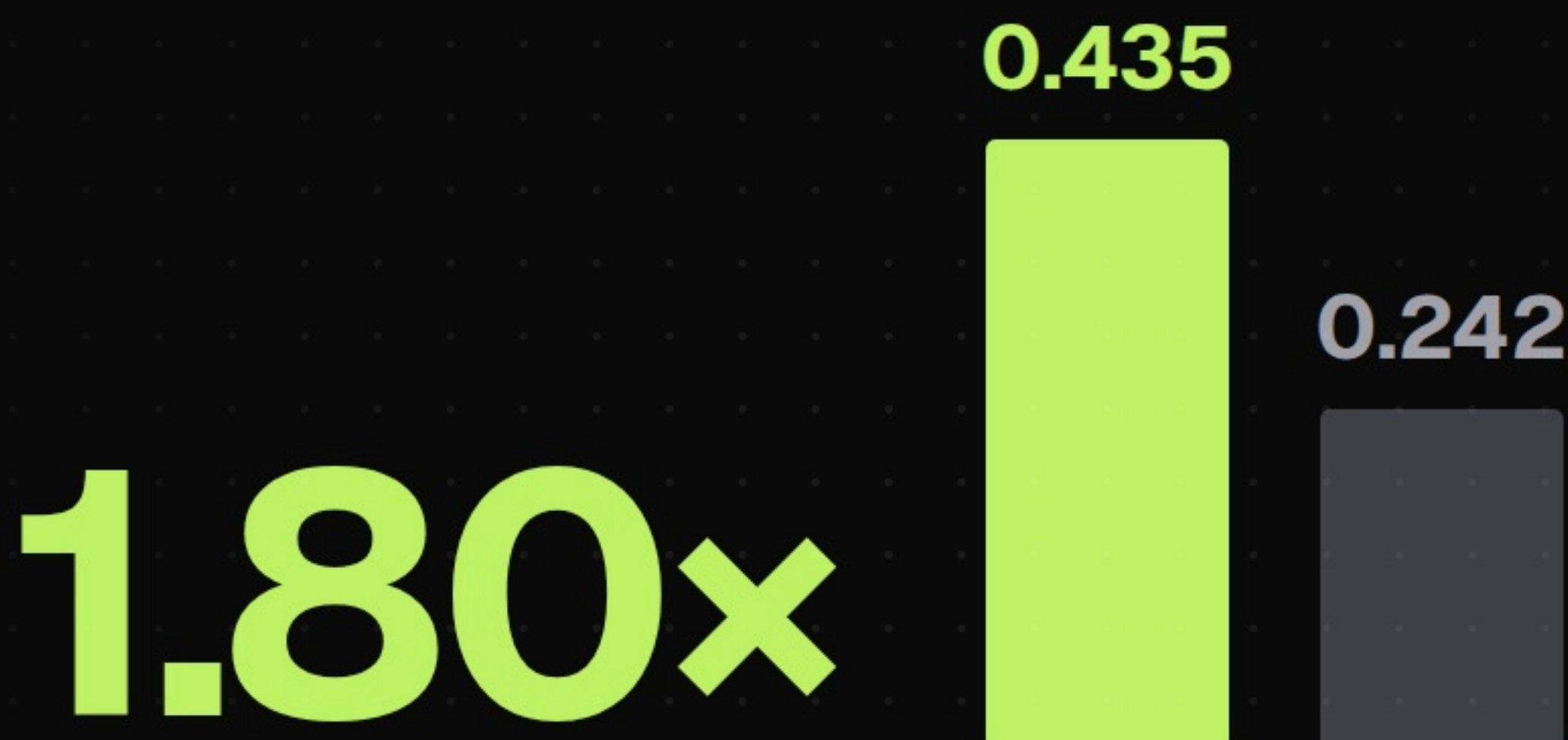
Beispiel



Anti-Slop Gatekeeper

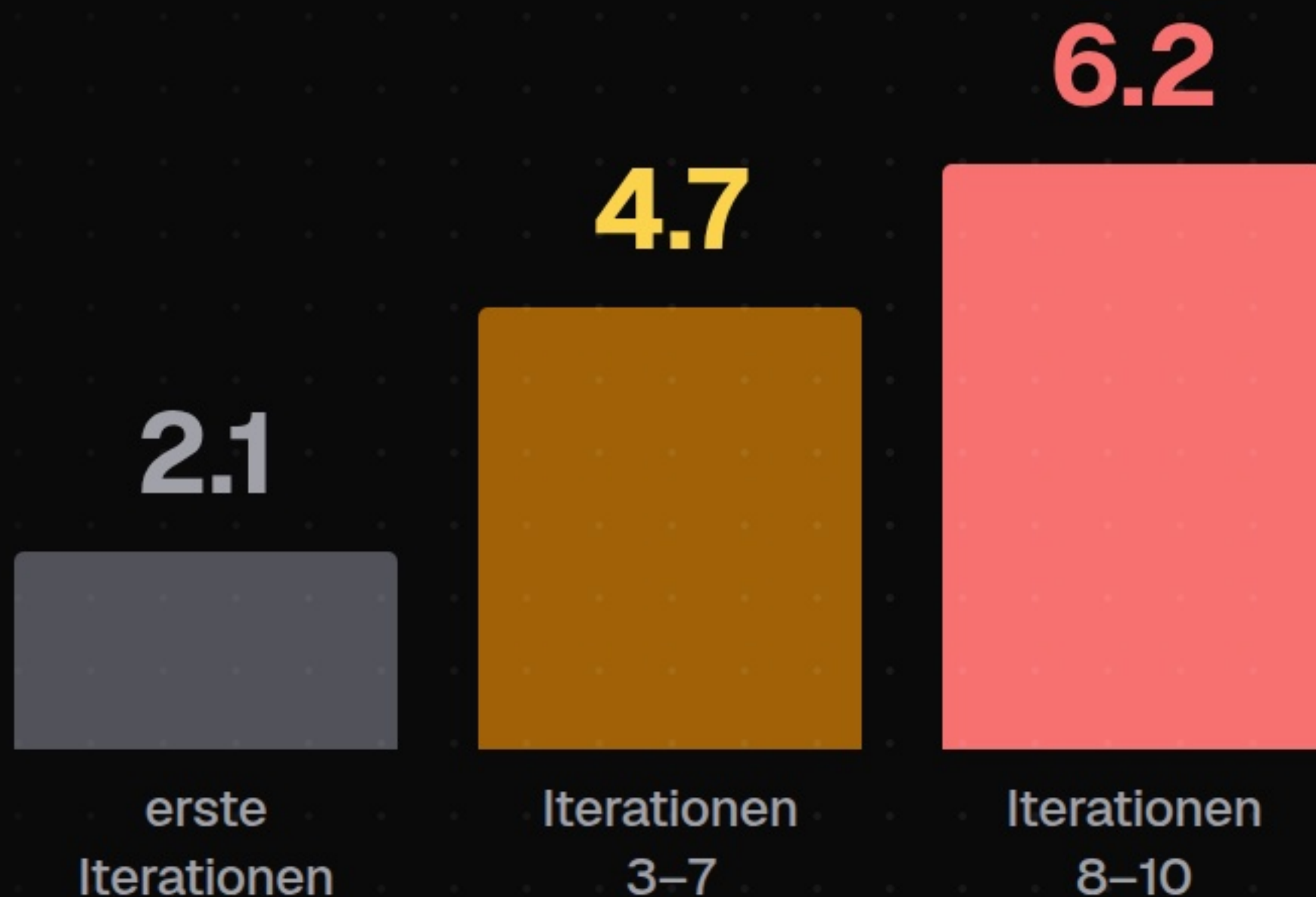
1 critical slop finding

KI-zugeordneter Code hatte mehr High-Severity-Befunde.



High-Severity-Befunde pro Datei: 955 KI-zugeordnete Dateien gegenüber 955 passenden menschlichen Kontrolldateien. Gleiche Richtung in JavaScript, Python und TypeScript.

Zehnmal „verbessern“ machte den Code unsicherer.



Durchschnittliche Schwachstellen pro Sample, wenn GPT-4o denselben Code immer wieder verbessern sollte. Auch Prompts, die ausdrücklich Sicherheit verlangten, fügten neue hinzu, nur weniger.

„Security Degradation in Iterative AI Code Generation“, IEEE-ISTAS 2025, arXiv 2506.11022. Signifikant zwischen frühen und späten Iterationen, nicht zwischen benachbarten.

Heute: ein Check an jedem Pull Request.

Ein kritischer Befund lässt den Check scheitern.

Warnungen blockieren nie einen Merge. Jeder Befund nennt seine Regel und, wo möglich, einen Ein-Klick-Fix.

Checks

Beispiel



Anti-Slop Gatekeeper

1 critical slop finding

unslop-gatekeeper

bot

Beispiel



SEC-031 (CRITICAL)

An error is silently swallowed and the handler returns a success response anyway, so failures (including skipped authorization checks) look identical to successes.



Suggested fix (1-click commit)

Check-Name, Titel und Kommentarformat sind die echten (englischen) Produkt-Strings. Befund und Code sind Beispieldaten.

Was es nicht kann. Noch nicht, oder nie.

Es ist nicht vollständig deterministisch.

119 Regeln aus veröffentlichter Forschung. 55 haben einen deterministischen Detektor, den Rest prüft ein LLM-Reviewer. Jeder Befund zeigt, wie er verifiziert wurde.

Der LLM-Review liest vorerst nur JS/TS.

Andere Sprachen prüft der deterministische Pre-Scanner.

Es vergleicht noch keine Revisionen.

Jeder Push wird einzeln geprüft. Einen Check scheitern zu lassen, weil eine Revision schlechter wurde, steht auf der Roadmap.

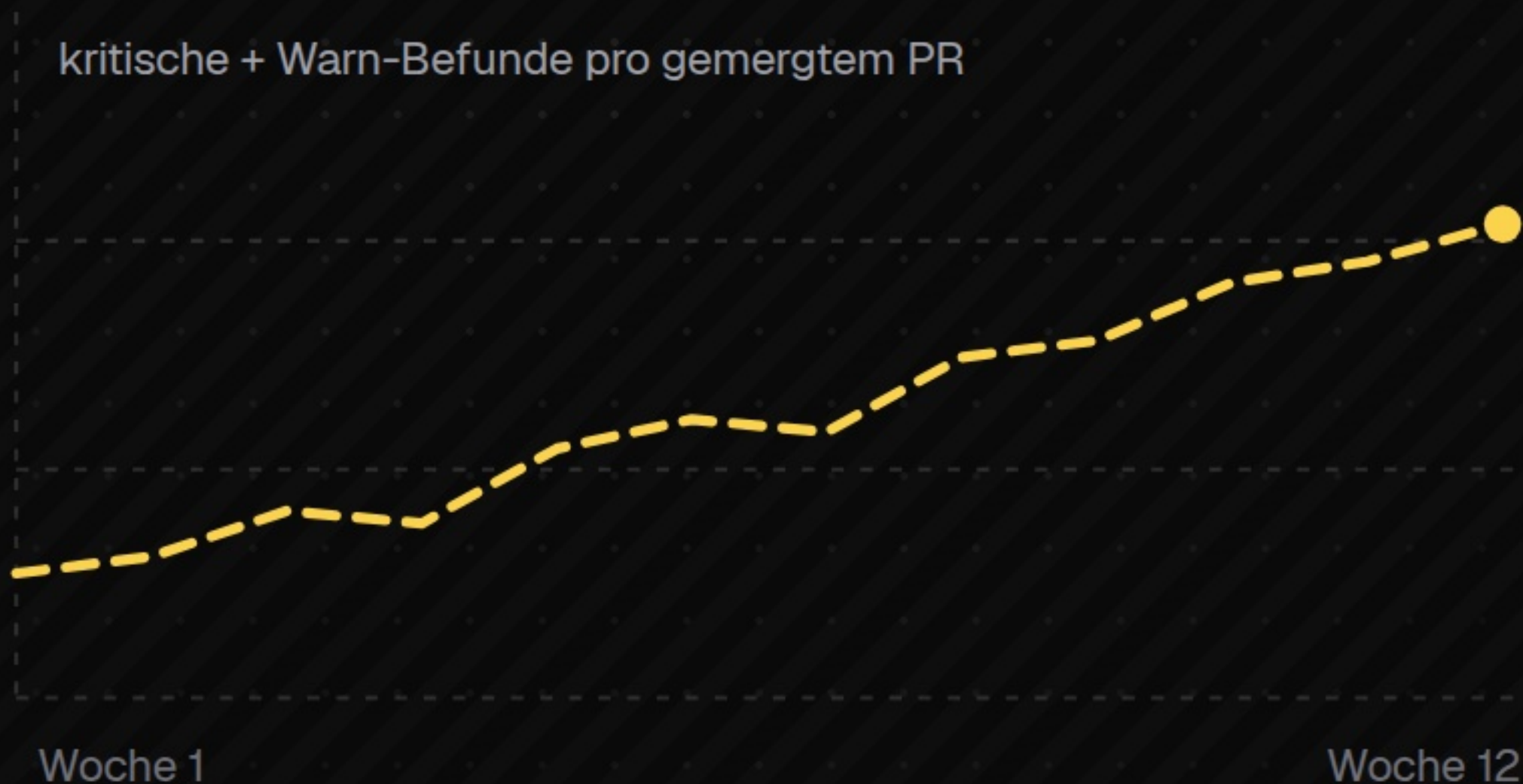
Es findet nicht alles.

Nichts blockiert 100 % der KI-Schwachstellen. Wir dokumentieren die Lücken.

Als Nächstes: der Trend, nicht nur der PR.

Geplant: Befunde pro Repository über die Zeit. So sehen Sie, ob KI-gestützte Änderungen schneller Schulden aufbauen, als Ihr Team sie abbaut.

Konzeptskizze · Beispieldaten · nicht gebaut



Welche Kennzahl in dieses Diagramm gehört, ist offen. Sagen Sie uns, was Sie messen würden.

Geplant: ein Nachweis pro Commit-SHA. Er listet, welche Regeln liefen und was bestanden hat. So können Sie einem Auditor oder Käufer einen Beleg geben statt einer Folie.

```
Repository      acme/shop
Commit         3f9c2a17de...
Regeln geprüft  119 (55 deterministisch)
kritisch       0
Warnungen       3, davon 1 von einem Menschen geprüft
nicht geprüft   0 Dateien
Signatur        ████████████████████████████████████████
```

Was er nie behaupten würde: „Dieser Code ist fehlerfrei.“

Wenn Sie eine Engineering-Organisation leiten: Was müsste dieser Nachweis zeigen, damit Sie ihm vertrauen?

Wir lesen jeden Kommentar. Die Antworten fließen in die Spezifikation.

Private Beta, Inferenz in der EU (Vertex AI, EU-Endpunkt).

Warteliste: unslop.codes